BEFORE YOU SIGN OFF ON AI

The AI you approved may not be the AI that's running. Sign-off is a licence, not a verdict.

namitzz.github.io/AI

VALUE

01 What would we lose if we switched it off tomorrow?

Why it matters. If nobody can answer, the AI isn't changing a decision that matters yet.

What good looks like. A named outcome with a baseline and target, and a clear answer to what breaks without it.

02 What does acting gain, and what does waiting cost?

Why it matters. Boards should weigh AI against the status quo, not against perfection.

What good looks like. The value of acting and the cost of delay are both estimated, in money and in risk.

RISK

03 What happens when someone tries to make it misbehave?

Why it matters. AI can be manipulated through its inputs: prompt injection, data leakage and poisoned data.

What good looks like. A threat model before build, adversarial testing before launch, and a security owner who signs off.

04 Which failure would we never want to explain in public?

Why it matters. Naming the unacceptable failure is how a board sets real limits.

What good looks like. A written risk appetite with named red lines, set by the board, with the EU AI Act risk tier checked where it applies.

READINESS

05 If the vendor updated the model last night, would we know?

Why it matters. Hosted models can change after approval. The system you tested may not be the one running.

What good looks like. Version pinning or change notices in vendor contracts. Re-testing triggered by material model changes, with routine updates handled through normal change control.

06 How fast can we go back to doing it by hand?

Why it matters. Rollback only works if the manual process still exists and people still know it.

What good looks like. A tested fallback procedure, a named person with authority to invoke it, and a recorded drill or recovery test. A manual fallback only counts if it can actually operate in practice.

ACCOUNTABILITY

07 Who can switch it off at 3am, and do they know it?

Why it matters. Accountability on paper fails if the person can't act when it matters.

What good looks like. A named owner with the authority and the means to stop it, tested in a drill.

08 Approving 200 AI outputs a day: is anyone still deciding?

Why it matters. At high volume, human review drifts into rubber-stamping (automation bias).

What good looks like. Review load sized so people can actually judge, with overrides logged and sampled.

BOARD SCORECARD __ /5

Score 1 only where there is evidence the control is operating; otherwise score 0. Mark a control as critical only where this system's risk assessment requires it. A critical control without evidence blocks approval, whatever the total. The score counts controls with evidence of operation. It is not a safety, maturity or compliance rating, a full score does not mean automatic approval, and it does not replace a system-specific risk assessment.

- ☐ **Policy.** Board-approved AI governance policy For example: the approved policy, the board minute approving it and a review date. ☐ CRITICAL
- ☐ **Inventory.** All AI identified, including shadow AI and agents For example: a current register of AI systems, vendors and agents, each with an owner. ☐ CRITICAL
- ☐ **Owner.** One accountable executive For example: documented ownership, including the authority to pause the system. ☐ CRITICAL
- ☐ **Appetite.** Risk appetite and tolerances defined For example: approved tolerances and the thresholds that trigger escalation. ☐ CRITICAL
- ☐ **Assurance.** Continuous assurance, not a one-off check For example: monitoring records against thresholds, drift checks, incident records and a tested fallback procedure. ☐ CRITICAL

INVESTMENT GATE

If a critical control fails, do not progress. An illustrative way to think about staged approval, not a validated method. Which controls are critical depends on each system's risk assessment.

1. Pilot: Approve test

- ☐ Use case and baseline
- ☐ Risk assessment and data owner
- ☐ Measurable success criteria

2. Scale: Approve rollout

- ☐ Performance thresholds met
- ☐ Failure scenarios tested
- ☐ Monitoring and override verified

3. Run: Licence

- ☐ Named owner and audit trail
- ☐ Drift and incident monitoring
- ☐ Reassessed after any material change

↻ Material change: reassess (model, data, permissions, connected tools or intended use), depending on risk and impact. Routine updates follow normal change control.

Informed by ISO/IEC 42001, NIST AI RMF, the EU AI Act and the UK AI principles. Illustrative examples for academic discussion. Not legal, compliance or professional advice, and not a validated or certified method.

Namit Sarna · MSc AI for Business Transformation, Aston University · linkedin.com/in/namitsarna